

README

Helix OTA — Phase 1.0.1 (Staged Rollout, Health-Gated Halt, Device-Side Trust, End-User Rollback)

Field	Value
Revision	2
Created	2026-06-07
Last modified	2026-06-08
Implementation status (2026-06-08)	Engine + schema landed. Migration 002 (deployment_phases/rollouts/rollback_history) is real-DB validated; the staged-rollout Go engine is wired via the ota-rollout-engine brick with REST POST/GET / deployments/{id}/rollout + / evaluate (create→start→advance→complete, halt-on-error-breach) — see server/internal/rollout + server/internal/api/handlers_rollout.go. End-user rollback is in 1.0.1 per the operator decision (its rollback_history table is migration 002). REMAINING: pgx StoragePort over migration 002 tables; device-side TUF; rollback UX.
Status	planned (outline — depth follows 1.0.0-MVP) The first post-MVP phase. Turns the MVP's all-at-once delivery into a safe, observable, staged rollout with automatic health-gated halt; adds device-side trust enforcement (TUF) and end-user rollback (explicitly deferred from MVP). Grounded in ADR-0001..0005 and the stack notes (hawkBit cascading rollouts, Foundries wave state machine, Memfault one-
Status summary	

Field	Value
	click abort, balena update-lock, go-tuf/v2).
Issues	Scope boundary with 1.0.2 (delta updates) to be finalized; device-side TUF client (gomobile vs hand-rolled Kotlin) needs the spike from ADR-0002.
Issues summary	Sequenced after MVP; several items gated on MVP spikes.
Fixed	initial phase outline
Fixed summary	Captured the deferred-from-MVP items in one phase with traceability to ADRs.
Continuation	Expand each section into full specs (engine design, SQL for deployment_phases/rollouts, device TUF client spec, rollback UX) under this directory, each adversarially reviewed and validated, then exported.

Table of contents

- [§1. Goals](#)
- [§2. Staged rollout engine](#)
- [§3. Health-gated halt + post-boot health window](#)
- [§4. Device-side trust \(TUF\)](#)
- [§5. End-user rollback](#)
- [§6. Data model deltas](#)
- [§7. New/changed components](#)
- [§8. Testing & evidence](#)

§1. Goals

Deliver controlled rollouts (5% → 10% → 30% → ... → 100%, arbitrary steps) with **automatic** safety: a cohort that regresses is halted/aborted without a human in the loop. Add the trust and rollback capabilities deliberately deferred from MVP. This is where the ota-rollout-engine submodule graduates from scaffold to implementation.

§2. Staged rollout engine

ota-rollout-engine (OS-agnostic): ordered phases {percentage, success_threshold, error_threshold, duration, auto_progress}; deterministic, stable cohort selection (hash of device-id so a device stays in its cohort across re-evaluation); idempotent state transitions; pause/resume/abort. Patterns adopted from the research: hawkBit threshold-gated cascading rollouts with

emergency shutdown; Foundries.io wave → canary → observe → expand-or-cancel; group/UUID/percentage targeting. **Safety invariant:** halt wins over advance when both could trigger in one evaluation window.

§3. Health-gated halt + post-boot health window

Beyond AOSP's boot-success mark, add a **post-boot health-confirmation window** (telemetry: crash rate, key service health, regression vs the previous release baseline) feeding automatic canary abort (Memfault/Foundries pattern). The MVP already ingests health and supports one-click manual abort (`server/telemetry_processing.md`); 1.0.1 makes the abort automatic and wires it to the rollout engine.

§4. Device-side trust (TUF)

Per ADR-0002: MVP ships signing + SHA-256 + AVB and a TUF-forward signer/verify seam. 1.0.1 makes **device-side TUF verification** mandatory after the spike that picks the on-device client (gomobile-wrapped go-tuf/v2 vs hand-rolled Kotlin), defines the offline key-custody ceremony, and adds the Director/Image repository split (Uptane-inspired, single-ECU tier — see `research/stacks/uptane.md`).

§5. End-user rollback

Deferred from MVP (operator: “not for first version”). Options to spec: A/B slot-pinning to the prior known-good build, server-driven “recall to version N-1” deployment, and a guarded device-local recovery path. Anti-downgrade (rollback-index) interplay must be preserved so rollback is authorized, not an attack (see `research/stacks/android-avb-rollback.md`). Multi-version rollback and delta-rollback are 1.0.2+.

§6. Data model deltas

Adds the tables intentionally omitted from MVP: `deployment_phases`, `rollouts` (+ wrapped-engine correlation id if ADR-0001 selects hawkBit), `rollback_history`, plus TUF metadata storage. Migration `002_*` extends the `helix_ota` schema; up/down validated against live Postgres as in MVP.

§7. New/changed components

`ota-rollout-engine` (implement), `ota-telemetry-schema` (health metrics), device-side TUF in `ota-android-agent`, control-plane rollout API (`/deployments` gains strategy + pause/resume/abort), dashboard rollout controls.

§8. Testing & evidence

Four-layer per component; rollout-engine gets deterministic-cohort + halt-wins property tests with mutation coverage; device TUF gets attack-class tests (rollback/freeze/mix-and-match). Real-device validation on Orange Pi 5 Max: staged cohort, induced regression → automatic halt, authorized rollback.